

AUDIT TEKNOLOGI INFORMASI

Studi Kasus

Reza Aminy, CISA CISM CRISC CGEIT CRMA CITA

Studi Kasus

Harus sesuai studi kasus, tidak boleh menggunakan hasil dari audit sebelumnya

Silakan pilih salah satu web (bebas) dan lakukan beberapa pemeriksaan *web server* menggunakan *open-source intelligence* (OSINT). Situs web antara satu peserta dengan peserta lain tidak boleh sama. Jika situs web sama, akan ada pengurangan nilai maksimal -25. Jika laporan audit sama persis, studi kasus mendapat nilai 0.

Jika ditemukan adanya kerentanan, laporkan temuan secara detail (dalam bentuk laporan, jangan dalam bentuk presentasi/narasi)

Cukup laporkan satu temuan saja. Jika temuan dilaporkan lebih dari satu, temuan yang akan dinilai hanya temuan pertama.

Prosedur Audit

Berikut ini ada tiga pemeriksaan yang dapat dilakukan. Masing-masing berbeda antara satu dengan yang lain.

Pilih salah satu untuk dilakukan, atau lakukan dua dari tiga pemeriksaan, yang hasilnya digabungkan ke dalam satu temuan, atau lakukan ketiganya, yang hasilnya digabungkan ke dalam satu temuan.

Pemeriksaan SSL/TLS dan HSTS	Pemeriksaan <i>Security Headers</i>	Identifikasi Komponen Rentan
Lakukan SSL/TLS <i>server test</i> menggunakan Qualys SSL Labs	Lakukan <i>scanning</i> keberadaan <i>security headers</i> (https://securityheaders.com/)	Gunakan <i>web application scanner/analyzer</i> (seperti Wappalyzer dan/atau AwesomeTechStack)
Lakukan pemeriksaan HSTS (https://domsignal.com/hsts-test)	Laporkan jika ada <i>security headers</i> yang tidak di-set	Laporkan apakah ada komponen-komponen <i>web server</i> yang menggunakan versi lama, dan <i>vulnerabilities</i> apa saja yang ada di versi lama tersebut
Laporkan temuan yang terdeteksi		

6 C

<i>Condition</i>	Judul harus menjabarkan temuan dan bukan sekadar keterangan. Setelah judul, deskripsikan temuan secara jelas dan ringkas.
<i>Criteria</i>	Sebutkan aturan/persyaratan yang tidak terpenuhi. Jangan diisi dengan narasi.
<i>Cause</i>	Penyebab termasuk akar permasalahan, <i>necessary conditions</i> , <i>sufficient conditions</i> , dan faktor pemicu
<i>Consequence</i>	Dampak langsung dan tidak langsung jika temuan tidak diperbaiki
<i>Category/classification</i>	Kategorisasi temuan antara lain berdasarkan signifikansi dampak, tingkat organisasi, atau klasifikasi lainnya
<i>Corrective action (CA)</i>	Rekomendasi perbaikan menyampaikan “what to do” dan bukan “how to” secara detail

Contoh 1

Security Headers Belum Diterapkan (judul)

Deskripsi

Berdasarkan pemeriksaan terhadap situs ... pada tanggal ..., ditemukan bahwa *security headers* belum diterapkan, yaitu:

- CSP
- ...

(dielaborasi dan didetailkan)

Kriteria

ISO/IEC 27001:2013 A.12.6 *Technical vulnerability management* (gunakan ISO/IEC 27001:2022 untuk bonus nilai)

Penyebab

Hal ini disebabkan karena proses pengamanan teknis belum dijalankan dengan lebih ketat **(dielaborasi dan didetailkan)**

Akibat

Terdapat kerentanan teknis yang dapat dieksploitasi dan menyebabkan berbagai macam hal termasuk kebocoran data dan *ransomware* **(dielaborasi dan didetailkan)**

Kategori

Tinggi

Rekomendasi

Penerapan *security headers* untuk meningkatkan keamanan situs dan penerapan proses pengamanan teknis secara lebih ketat **(dielaborasi dan didetailkan)**

Lampiran

Screenshot dari evidence

Contoh 2

Penggunaan Komponen Web yang Memiliki *Vulnerabilities*

Deskripsi

Berdasarkan pemeriksaan terhadap situs ... pada tanggal ..., ditemukan bahwa ... masih menggunakan versi lama yaitu versi... dan belum diperbarui menjadi versi ... Versi ini memiliki *vulnerabilities* ..., ..., dan ... **(dielaborasi dan didetailkan)**

Kriteria

ISO/IEC 27001:2013 A.12.6 *Technical vulnerability management* (gunakan ISO/IEC 27001:2022 untuk bonus nilai)

Penyebab

Hal ini disebabkan karena proses *vulnerability and patch management* belum dijalankan dengan lebih ketat **(dielaborasi dan didetailkan)**

Akibat

Terdapat kerentanan teknis yang dapat dieksploitasi dan menyebabkan berbagai macam hal termasuk kebocoran data dan *ransomware* **(dielaborasi dan didetailkan)**

Kategori

Tinggi

Rekomendasi

... di-*upgrade* ke versi terbaru yaitu versi ...

Selain itu proses *vulnerability and patch management* perlu dijalankan dengan lebih ketat, yaitu antara lain identifikasi versi terbaru secara tepat waktu dan *upgrade* secara aman. **(dielaborasi dan didetailkan)**

Lampiran

Screenshot dari evidence

Komponen Penilaian

Komponen	Nilai
Judul	10
Deskripsi	20
Kriteria	15
Penyebab	10
Akibat	20
Kategori	5
Rekomendasi	10
Bukti (lampiran)	10
Nilai Total	100

Contoh Penilaian

Pemeriksaan Security Headers

Deskripsi

Berdasarkan pemeriksaan terhadap situs bahwa Medium Security Risk masih menggunakan versi yaitu CloudFlare dan Tidak ditemukan pengalihan dari HTTP ke HTTPS

Kriteria

Terdeteksi bahwa host mengimplementasikan RFC1323/RFC7323

Penyebab

Tidak ada token Anti-CSRF yang ditemukan dalam formulir pengiriman HTML.

Komponen dan Penilaian	Nilai
Judul: bukan temuan	0 dari 10
Deskripsi: deskripsi tidak sinkron dengan judul	10 dari 20
Kriteria: kriteria tidak sinkron dengan judul dan deskripsi	0 dari 15
Penyebab: penyebab tidak sinkron dengan judul, deskripsi, dan kriteria	0 dari 10

Contoh Penilaian

Akibat

Terdapt berisiko seperti :

Absence of Anti-CSRF Tokef CSP Wildcard Directive

CSP: script-src unsafe-inline

Content Security Policy (CSP) Header Not Set

Missing Anti-clickjacking Header

Vulnerable JS Library Cookie No HttpOnly Flag

Kategori

Sedang atau Tinggi

Rekomendasi

Penerapan security headers

Komponen dan Penilaian	Nilai
Akibat: berisi penjelasan untuk deskripsi dan/atau penyebab. Penjelasan akibat kurang jelas	5 dari 20
Kategori: kategori hanya satu	0 dari 5
Rekomendasi: kurang sinkron dengan deskripsi, kriteria, dan penyebab	5 dari 10
Bukti (lampiran): tidak ada	0 dari 10
Nilai Total	20 dari 100

Terima kasih!

Q & A